课程编号：

《开源创新思维》

平时作业报告

Apache Commons CLI 许可证合规扫描与分析

作业 1 · 第 2 章 开源合规与许可证

姓　　名	宋佳威	学　　号	F2505437
班　　级	F25017	指 导 教 师	祝欣蓉
开 设 学 期	2026-2027 秋季学期		
开 设 时 间	第 1 周——第 16 周		
报告日期	2026 年 10 月 29 日		
评 定 成 绩		评 定 人	祝欣蓉
		评 定 日 期	

年级：大二

上海杉达学院

AI 辅助实际实验与分析复核稿：课程禁止代写；本人须复现、理解并修订后提交。

1、开源项目介绍

本次选择 Apache 软件基金会 Apache Commons 项目下的 Commons CLI。它是 Java 命令行参数解析库，可定义选项、解析参数并生成帮助信息。例如，程序可用它区分“--help”和带值的参数。仓库为 apache/commons-cli，项目许可证为 Apache-2.0。[1][2]

为保证复现，选择固定版本 1.9.0，标签 rel/commons-cli-1.9.0；未将其描述为最新版本。源码提交为：
698b238276c0e22e97e4aec703a0b00201d29666

被测输入是 GitHub 提交源码快照，并非 Apache 正式发行压缩包。扫描解压后的全部 116 个文件，包括 .github 等隐藏目录，无自定义排除。范围涵盖 Java 主源码、测试、配置、网站资源和许可文件，不含 Git 历史、Maven 下载依赖、构建产物或容器镜像。

2、工具选择、安装过程及问题

选用 Apache Creadur 的 Apache Rat 0.16.1。它适合检查 Apache 源码的许可证头及发布材料；工具本身也采用 Apache-2.0。相较于可识别更多许可证、版权和包信息的 ScanCode Toolkit，Rat 检查范围更窄；FOSSology 提供多扫描器和协作复核，但部署更重。本实验聚焦源码发布前的许可证头检查，因此采用易于复跑的 Rat 单个 JAR，并保留全部原始结果。[3]

实验环境为 macOS 26.6.2（arm64）和已安装的 OpenJDK 17.0.18。先运行 java -version 确认环境；从 Maven Central 获取官方 org.apache.rat:apache-rat:0.16.1 JAR，执行 --help 验证可运行；从 GitHub 下载上述固定提交的源码压缩包并解压到 source。此方式不需要安装 Maven，也没有重新安装 Java。

下载及扫描成功，未出现需要修复的安装错误。实际问题为扫描范围界定与未知项解释。环境、下载及扫描日志分别见 evidence/environment.txt、installation.log 和 scan-*.log；未把未发生的安装失败写作实验经历。工具及源码下载地址、SHA-256 均记入 provenance.json；本地散列用于固定实验输入，不替代发布者签名验证。

核心扫描命令如下；完整下载、核验和复跑步骤见同目录 README.md。

```
java -jar tools/apache-rat-0.16.1.jar --scan-hidden-directories source > rat-report.txt
java -jar tools/apache-rat-0.16.1.jar --scan-hidden-directories -x source > rat-report.xml
```

首次记录时间为 2026-10-29 13:29:09（北京时间）。只使用报告参数，不使用自动加许可证头参数，避免改变被测源码。

3、工具输出的检测报告

以下为 evidence/rat-report.txt 的原始摘要与待核文件清单摘录。完整逐文件 TXT 和原始 XML 均随仓库提交；为满足五页限制，报告正文不重复粘贴整份 116 文件清单。

Summary

Generated at: 2026-10-29T13:29:09+08:00

Notes: 3
Binaries: 4
Archives: 0
Standards: 109

Apache Licensed: 106
Generated Documents: 0

3 Unknown Licenses

Files with unapproved licenses:
  source/.gitignore
  source/src/site/resources/download_cli.cgi
  source/src/site/resources/profile.jacoco

统计项	数量	判读
标准文本资源	109	106 个 AL + 3 个 Unknown
通知/许可类资源	3	LICENSE、NOTICE、RELEASE-NOTES
二进制资源	4	logo.xcf、1x1.gif、logo.png、options.png
全部资源	116	109 + 3 + 4；与源文件清单一致

AL 表示识别到 Apache License 2.0 文件头；N/B 分别表示通知类/二进制文件。106/109≈97.25% 仅为标准文本资源的头部识别比例，不是“项目合规率”。3 份通知类文件和 4 份二进制文件没有经过同样的许可证头批准判断，不能并入已批准数。

4、检测结果详细分析

4.1 主要证据与适用范围

XML 中 106 个标准文件标记为 Apache License Version 2.0 且 license-approval=true。主源码 26 个 Java 文件、测试目录 39 个 Java 文件均为 AL；LICENSE.txt 包含 Apache-2.0 正文，NOTICE.txt 载明 Apache Commons CLI、2002—2024 年 ASF 版权及基金会归属声明。这些证据支持“所扫主要 Java 源码许可证头一致”的结论，不能证明所有法律义务均已满足。

4.2 三项 Unknown 的逐项人工复核

（1）.gitignore：内容为构建产物及 IDE 忽略规则，开头包含指向 github/gitignore 固定提交的来源 URL，但没有可识别许可证头。应核实对应提交的来源及适用许可，并在确有授权时补充适当说明；若发布审查允许排除此类配置，应记录理由、范围和复核人。当前保留 Unknown，不根据仓库总许可证擅自给外部来源内容改授权。

（2）src/site/resources/download_cli.cgi：是带 #!/bin/sh 的短脚本，调用 Apache 的 mirrors.cgi，没有可识别许可证头。应核查提交历史及版权来源，确认授权后在 shebang 后加入合法许可证注释并复扫；若仅供网站部署、不进入发行包，也应验证发布清单并记录处置。没有来源证据前不能直接自动补 Apache 头。

（3）src/site/resources/profile.jacoco：实际为 0 字节，Rat 无文本可匹配。空文件不等于许可证违规；应检查构建/站点是否需要它。若为必要占位文件，记录“空文件、无可扫描文本”的经复核例外；若无用途可在维护分支删除后验证构建。此次不修改上游快照，原始结果保留待核状态。

4.3 其他风险和检查充分性

4 个图像/设计文件只被分类为 binary，仍需核对来源、作者许可及商标使用；3 份 notice 类文件要人工核查是否完整、是否随目标发行物提供。Rat 的“unapproved”是规则未批准，不是法律上认定侵权；同样，AL 也不验证作者是否真正有权许可。

pom.xml 显式列出的 JUnit Jupiter、Commons IO、Mockito 均标为 test scope，但未解析父 POM、构建插件及传递依赖，不能据此宣称“无第三方依赖风险”。本次未构建 JAR，也未执行功能测试或漏洞检测。若用于正式交付，应以实际发行物为边界补充依赖解析、SBOM、许可证/版权扫描、二进制溯源及人工审批。

本实验的充分性标准是：固定来源与工具版本、覆盖 116/116 个输入、可由 TXT/XML 独立核对统计、逐项说明 3 个待核问题。该标准满足本次限定的许可证头实验，不等于完整软件成分分析。

4.4 Apache-2.0 使用义务与最终结论

Apache-2.0 允许在满足条件时商用、修改及闭源再分发；分发时应提供许可证副本，对修改文件作显著标记，在分发的源代码中保留仍相关的版权、专利、商标及归属声明。如原作品含 NOTICE，应按第 4(d)条在规定位置保留仍相关的归属内容。第 3 条规定特定专利诉讼会终止相应专利授权；第 6 条通常不授予商标使用权。不能只因“宽松许可证”就删掉 LICENSE/NOTICE。[2]

结论：本次 116 个资源中，106 个标准文件识别为 Apache-2.0，3 个标准文件需人工复核，另有 3 个通知类和 4 个二进制文件需按类型核查。未在扫描范围内识别到另一种文本许可证，不等于不存在第三方许可问题。正式分发前须完成上页处置及实际交付物检查；本报告不作“全面合规”保证。

实验执行与文字整理使用了 AI 辅助；提交前，学生应依据 README 亲自复现、理解 Unknown 的含义并复核结论。报告仅陈述已保存的实验事实，不虚构个人操作经历或学习感受。

依据与证据（访问/实验日期：2026-10-29）

[1] Apache Commons CLI 官方项目： https://commons.apache.org/proper/commons-cli/

[2] Apache License 2.0 原文： https://www.apache.org/licenses/LICENSE-2.0

[3] Apache Rat 官方说明： https://creadur.apache.org/rat/

[4] 固定源码、文件散列及原始输出：evidence/provenance.json、source-file-manifest.csv、rat-report.txt、rat-report.xml、source-excerpts/；命令与复现说明见 README.md。

课件延伸练习（MIT/GPL 比较、闭源集成、自有网站四文件补扫与组件清单）见 companion-exercises.md；独立于本五页报告。

评价表格（保留教师原模板，待教师填写）

考核标准	得分
（1）报告格式规范、语言通顺（10%）；	
（2）质量标准分析合理（10%）；	
（3）测试方法分析全面、合理（20%）；	
（4）测试风险分析全面、合理（20%）；	
（5）测试总体测试策略全面、合理（30%）	
（6）测试充分性判断标准合理（10%）	